Защищенные информационные системы

Павел Пархомец
Заместитель руководителя отдела ИБ RWB

Лекция 4

Сканирование по уровням OSI

```
+-------------------------------------+
|        APPLICATION SCANNING         |
|             (NUCLEI)                |
|                                     |
|   HTTP / API / Templates / Logic    |
|   vulnerability detection           |
+------------------ L7 -----------------+

+-------------------------------------+
|        TRANSPORT SCANNING            |
|             (NMAP)                   |
|                                     |
|     TCP SYN scan / UDP scan         |
|     port state detection            |
+------------------ L4 -----------------+

+-------------------------------------+
|        NETWORK DISCOVERY             |
|             (NMAP)                  |
|                                     |
|        ICMP / ARP discovery         |
|        find alive hosts             |
+------------------ L3 -----------------+
```

Nuclei

Nuclei - это быстрый, эффективный и расширяемый сканер уязвимостей.

Nuclei engine использует шаблоны текстовых файлов для определения шагов, необходимых для обнаружения уязвимости.

https://github.com/projectdiscovery/nuclei

Архитектура

Архитектура Nuclei

```
Targets (URLs/IPs/domains)
        |
        v
+--------------------+        +----------------------------+
|   Input / Normalize|        |   Template Repository      |
| - parse targets    |<------>| - YAML templates           |
| - expand scope     |        | - workflows                |
+---------+----------+        +-------------+--------------+
          |                               |
          v                               v
+------------------------------------------------------------+
|                      NUCLEI ENGINE                         |
|  Scheduler + Executor + Result Pipeline                    |
|                                                            |
|  1) Template Loader & Compiler                             |
|     - parse YAML                                           |
|     - compile matchers/DSL/extractors                      |
|                                                            |
|  2) Planner / Scheduler                                    |
|     - build "template x target" jobs                       |
|     - concurrency, rate-limit, retries                     |
|                                                            |
|  3) Protocol Executors                                     |
|     - HTTP / DNS / TCP / TLS / WHOIS / Headless ...        |
|     - send requests, collect responses                     |
|                                                            |
|  4) Matching & Extraction                                  |
|     - matchers (word/regex/status/DSL/...)                 |
|     - extractors (regex/json/xpath/...)                    |
|     - optional chaining via extracted values               |
|                                                            |
|  5) Reporting / Output                                     |
|     - stdout/json/sarif/..                                 |
|     - dedupe, severity, metadata                           |
+------------------------------------------------------------+
```

Шаблоны

Шаблоны

Шаблон Nuclei - это файл YAML. Данные разметки в файле сообщают Nuclei, что отправлять хосту и что искать в ответе хоста, чтобы определить, уязвим ли он.

Шаблоны

Шаблон Nuclei - это файл YAML. Данные разметки в файле сообщают Nuclei, что отправлять хосту и что искать в ответе хоста, чтобы определить, уязвим ли он.

Nuclei engine использует “кластеризацию шаблонов” для оптимизации количества запросов, отправляемых целевому объекту, и сокращения сетевого трафика.

Шаблоны

Template (YAML) — это декларативное описание:

- какие запросы сделать (один или несколько)
- какие условия считать успешным “нахождением”
- что извлечь из ответа (для вывода или для следующих шагов)

Шаблоны

```yaml
id: some-check

info:
  name: ...
  severity: low|medium|high|critical
  tags: ...

requests:           # или http:/dns:/tcp: в новых стилях
  - method: GET
    path:
      - "{{BaseURL}}/..."
    headers: ...
    matchers:
      - type: word/regex/status/dsl
    extractors:
      - type: regex/json/xpath
```

Как движок исполняет шаблон

1. Парсит YAML → строит внутреннюю модель шаблона.
2. Компилирует matchers/DSL → чтобы быстро проверять условия.
3. Создаёт задачи вида: (target, template, request-step).
4. Executor отправляет запросы через соответствующий protocol executor.
5. Получает response context (status, headers, body, timing, dns answers…).
6. Matchers решают: “есть сработка или нет”.
7. Extractors вытаскивают значения (иногда для chaining).
8. Формирует Finding (id, name, severity, matched-at, evidence) → отдаёт в output.

Matchers: “логика срабатывания”

Типовые matcher’ы:

1. status: коды ответа (200/403/500)
2. word: наличие строки(строк)
3. regex: регулярки
4. dsl: выражения над контекстом ответа (комбинирование условий)
5. binary / size / duration: реже, но полезно

Extractors: “доказательства и переменные”

Extractor’ы:

- regex (вытащить версию/токен/путь)
- json (jq-подобное извлечение)
- xpath (для HTML/XML)
- header/cookie

Зачем:

- показать “evidence” в отчёте
- подставить в следующий запрос (chaining), например:
  a. сначала достать csrf_token, потом отправить POST

Пример шаблона

```yaml
id: htpasswd

info:
  name: Detect exposed .htpasswd files
  author: geeknik
  severity: info
  tags: config,exposure

requests:
  - method: GET
    path:
      - "{{BaseURL}}/.htpasswd"

    matchers-condition: and
    matchers:
      - type: word
        words:
          - ":{SHA}"
          - ":$apr1$"
          - ":$2y$"
        condition: or

      - type: status
        status:
          - 200
```

Использование

Использование

```
nuclei -u https://my.target.site

nuclei -u my.target.site:5759

nuclei -l /path/to/list-of-targets.txt
```

Использование

```
> subfinder -d targetdomain.com -silent | httpx | nuclei -t tech-detect.yaml
```

Фильтрация шаблонов

-as (Automatic Selection)

> nuclei -u https:// my.target.site -as

Фильтрация шаблонов

-as (Automatic Selection)

> nuclei -u https:// my.target.site -as

```
admin@ip-172-31-41-76:~$ nuclei -u https://uber.com -as

                     __     _
   ____  __  _____/ /__  (_)
  / __ \/ / / / ___/ / _ \/ /
 / / / / /_/ / /__/ /  __/ /
/_/ /_/\__,_/\___/_/\___/_/   2.7.2

                projectdiscovery.io

[WRN] Use with caution. You are responsible for your actions.
[WRN] Developers assume no liability and are not responsible for any misuse or damage.
[INF] Using Nuclei Engine 2.7.2 (latest)
[INF] Using Nuclei Templates 9.0.7 (latest)
[INF] Templates added in last update: 40
[INF] Templates loaded for scan: 3438
[INF] Executing wappalyzer based tech detection on input urls
[INF] Executing tags (cloud,cdn,envoy,google) for host https://uber.com (41 templates)
[2022-06-19 01:32:08] [azure-domain-tenant] [http] [info] https://login.microsoftonline.com:443/uber.com/v2.0/.w
ell-known/openid-configuration [5bd1450c-8b7b-4877-aab8-688d37a70b6e]
```

Выбор определенного шаблона

-t (Specific Templates By Filename)

> nuclei -u https://my.target.site -t file/logs/python-app-sql-exceptions.yaml -t exposures/files/pyproject-disclosure.yaml

Выбор определенного шаблона

-t (Specific Templates By Folder)

```
> nuclei -u https://my.target.site -t file/logs -t exposures/files -t cves/2021
```

Выбор определенного шаблона

-tags (Select Templates By Tag)

> nuclei -u https://jira.targetdomain.site -tags jira,generic

Выбор определенного шаблона

-s (Select Templates By Severity)

> nuclei -u https://jira.targetdomain.site -s critical,high,medium,low,info

Пример шаблона

```yaml
id: htpasswd

info:
  name: Detect exposed .htpasswd files
  author: geeknik
  severity: info
  tags: config,exposure

requests:
  - method: GET
    path:
      - "{{BaseURL}}/.htpasswd"

    matchers-condition: and
    matchers:
      - type: word
        words:
          - ":{SHA}"
          - ":$apr1$"
          - ":$2y$"
        condition: or

      - type: status
        status:
          - 200
```

Создание шаблона

Зачем?

- Нашли новую уязвимость и хотите написать PoC
- Вышла новая уязвимость, нужно проверить свои ресурсы, что ее нет

Создание шаблона

Шаблоны должны содержать:

- Идентификатор шаблона
- Информация о шаблоне
- Какие данные отправлять на удаленный хост
- Инструкции по анализу ответа

Создание шаблона

```
id: my-test-nuclei-template

info:
  name: X Debug header fuzzing
  author: me
  severity: info
  description: Discover x-*-debug request headers

# TODO: what data to send to the remote host
# TODO: instructions on how to analyze the response
```

Создание шаблона

```
requests:
  - raw:
      - |
        GET / HTTP/1.1
        Host: {{Hostname}}
        X-{{fuzz}}-debug: 1

    redirects: true
    attack: batteringram
    payloads:
      fuzz: /var/tmp/fuzz.txt
```

Создание шаблона

```
requests:
  - raw:
      - |
        GET / HTTP/1.1
        Host: {{Hostname}}
        X-{{fuzz}}-debug: 1

    redirects: true
    attack: batteringram
    payloads:
      fuzz: /var/tmp/fuzz.txt
```

```
    payloads:
        fuzz:
            - abc
            - def
            - test
            - xyz
            - php
            - derp
```

Создание шаблона

Matcher — это функция, которая может использовать несколько методов для проверки ответа хоста и сравнения его элементов со значениями, которые мы определяем.

Создание шаблона

Request

Pretty Raw Hex

```
1  GET / HTTP/1.1
2  Host: 10.3.3.52
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:91.0)
   Gecko/20100101 Firefox/91.0
4  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/w
   ebp,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate
7  Upgrade-Insecure-Requests: 1
8  Sec-Fetch-Dest: document
9  Sec-Fetch-Mode: navigate
10 Sec-Fetch-Site: none
11 Sec-Fetch-User: ?1
12 Te: trailers
13 Connection: close
14
15
```

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Date: Fri, 17 Jun 2022 04:39:16 GMT
3  Server: Apache/2.4.29 (Ubuntu)
4  Vary: Accept-Encoding
5  Content-Length: 109
6  Connection: close
7  Content-Type: text/html; charset=UTF-8
8
9  <html>
10   <body>
11     <center>
         Nothing to see here
       </center>
       <p>
12       <center>
           <img src="shiba.jpg">
         </center>
13     </body>
14   </html>
15
```

Создание шаблона

```yaml
stop-at-first-match: false
matchers:
  - type: dsl
    dsl:
      - "len(body) > 109"
```

Создание шаблона

```yaml
id: my-test-nuclei-template
info:
    name: X Debug header fuzzing
    author: me
    severity: info
    description: Discover x-*-debug request headers

requests:
  - raw:
      - |
        GET / HTTP/1.1
        Host: {{Hostname}}
        x-{{fuzz}}-debug: 1

    payloads:
        fuzz: /var/tmp/fuzz.txt
    attack: batteringram

    redirects: true
    stop-at-first-match: false
    matchers:
      - type: dsl
        dsl:
          - "len(body) > 109"
```

Создание шаблона

```
┌──(user㉿kali)-[~]
└─$ nuclei -t /var/tmp/test.yaml -u http://10.3.3.52/

                     __     _
   ____  __  _____  / /__  (_)
  / __ \/ / / / __ \/ / _ \/ /
 / / / / /_/ / /_/ / /  __/ /
/_/ /_/\__,_/\____/_/\___/_/   2.7.2

                projectdiscovery.io

[WRN] Use with caution. You are responsible for your actions.
[WRN] Developers assume no liability and are not responsible for any misuse or damage.
[INF] Using Nuclei Engine 2.7.2 (latest)
[INF] Using Nuclei Templates 9.0.7 (latest)
[INF] Templates added in last update: 40
[INF] Templates loaded for scan: 1
[2022-06-17 14:45:08] [my-test-nuclei-template] [http] [info] http://10.3.3.52/ [fuzz=php]
```

Примеры “боевых” шаблонов Nuclei

Airflow без аутентификации

```yaml
id: unauthenticated-airflow-instance

info:
  name: Unauthenticated Airflow Instance
  author: dhiyaneshDK
  severity: high
  metadata:
    shodan-query: title:"Airflow - DAGs"
  tags: apache,airflow,unauth

requests:
  - method: GET
    path:
      - "{{BaseURL}}"
      - "{{BaseURL}}/admin/"

    stop-at-first-match: true
    matchers-condition: and
    matchers:
      - type: word
        part: body
        words:
          - "<title>Airflow - DAGs</title>"

      - type: status
        status:
          - 200
```

FTP без аутентификации

```yaml
id: unauth-ftp

info:
  name: FTP Anonymous Login
  author: C3l3si4n
  severity: medium
  reference:
    - https://tools.ietf.org/html/rfc2577
  tags: network,ftp

network:
  - inputs:
      - data: "USER anonymous\r\nPASS nuclei\r\n"

    host:
      - "{{Host}}:21"
      - "{{Hostname}}"

    matchers:
      - type: word
        words:
          - "Anonymous access allowed,"
        part: response
```

SQL injection

```yaml
id: SQLI-ERROR

info:
  name: sqli-header-error
  author: MR.iambatman
  severity: high
  description: sqli-error

requests:

  - raw:
      - |
        GET /§sqli§ HTTP/1.1
        Host: {{Hostname}}
        User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0
        §header§: §sqli§

      - |
        POST /§sqli§ HTTP/1.1
        Host: {{Hostname}}
        User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0
        §header§: §sqli§
        Content-Type: application/x-www-form-urlencoded

      - |
        PUT /§sqli§ HTTP/1.1
        Host: {{Hostname}}
        User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0
        §header§: §sqli§
        Content-Type: application/x-www-form-urlencoded

    payloads:
      header: helpers/payloads/request-headers.txt
      sqli: helpers/payloads/sqli.txt

    attack: clusterbomb
    redirects: true

    matchers-condition: and
    matchers:
      - type: regex
        regex:
          # MySQL
          - "SQL syntax.*?MySQL"
          - "Warning.*?\\Wmysqli?_"
          - "MySQLSyntaxErrorException"
          - "valid MySQL result"
          - "check the manual that (corresponds to|fits) your MySQL server version"
          - "Unknown column '[^ ]+' in 'field list'"
          - "MySqlClient\\."
          - "com\\.mysql\\.jdbc"
          - "Zend_Db_(Adapter|Statement)_Mysqli_Exception"
          - "Pdo[./_\\\\]Mysql"
          - "MySqlException"
          - "SQLSTATE\\[\\d+\\]: Syntax error or access violation"
          # MariaDB
          - "check the manual that (corresponds to|fits) your MariaDB server version"
          # Drizzle
          - "check the manual that (corresponds to|fits) your Drizzle server version"
          # MemSQL
          - "MemSQL does not support this type of query"
          - "is not supported by MemSQL"
          - "unsupported nested scalar subselect"
          # PostgreSQL
          - "PostgreSQL.*?ERROR"
          - "Warning.*?\\Wpg_"
          - "valid PostgreSQL result"
          - "Npgsql\\."
          - "PG::SyntaxError:"
          - "org\\.postgresql\\.util\\.PSQLException"
          - "ERROR:\\s\\ssyntax error at or near"
          - "ERROR: parser: parse error at or near"
          - "PostgreSQL query failed"
          - "org\\.postgresql\\.jdbc"
```

OpenVAS (Greenbone)

(Смотрим в отдельном доке)